

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 06

Domain II - Information Security Risk Management

30 Questions	48 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 48 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM2-028)

Which statement BEST defines risk capacity?

- A. The maximum level of risk the organization can absorb while remaining viable
- B. The acceptable deviation from a limit for a specific process
- C. The exposure remaining after current controls are considered
- D. The amount and type of risk the organization chooses to pursue

Question 2 (CISM2-029)

Why is the business owner essential when determining the criticality of an information asset?

- A. The owner can relate loss of confidentiality, integrity, or availability to business objectives and consequences
- B. The owner is always responsible for configuring the asset's technical safeguards
- C. The owner can certify that every vulnerability has been identified
- D. The owner independently determines the organization's overall risk appetite

Question 3 (CISM2-030)

Scenario: A payment company is entering a new country through a joint venture. The venture's growth plan assumes more service disruption than the parent company normally tolerates, while the parent remains responsible for customer commitments.

What should the information security manager do FIRST when assessing the venture's technology risks?

- A. Use the venture's tolerance because it operates the local services
- B. Use the parent company's lowest technical threshold for every scenario
- C. Postpone the assessment until the venture has experienced operational losses
- D. Clarify applicable enterprise appetite, delegated tolerances, objectives, and accountability with the relevant leaders

Question 4 (CISM2-031)

Scenario: A city classifies its public website as low criticality. During a risk workshop, the security manager learns that the same hosting environment provides an unpublished interface used by emergency dispatch to retrieve road-closure data.

Which action is MOST appropriate?

- A. Reassess the shared environment based on the dispatch dependency and availability impact
- B. Retain the website rating because public content has low confidentiality
- C. Rate every city website as critical because they share a domain name
- D. Assess only the interface code because hosting dependencies are operational matters

Question 5 (CISM2-032)

Scenario: A travel group uses three reservation vendors in different regions. Due diligence shows that all three obtain fraud screening from the same specialist provider, which has no tested alternate processing site.

Which risk should be added to the assessment?

- A. A correlated service interruption caused by the shared fourth-party dependency
- B. A guaranteed breach caused by using outsourced fraud screening
- C. A pricing risk because the reservation vendors operate in different regions
- D. A control failure solely because the specialist provider lacks a client contract

Question 6 (CISM2-033)

Scenario: A construction firm identifies exposed remote access on a project server, active credential-phishing campaigns against engineers, and the possibility that altered blueprints could cause rework and safety delays.

How should these elements be classified?

- A. Remote access is the impact, phishing is the vulnerability, and rework is the threat
- B. All three are control deficiencies because they contribute to one scenario
- C. Remote access is the threat, phishing is the impact, and rework is the vulnerability
- D. Remote access is the vulnerability, phishing is the threat, and rework and delay are impacts

Question 7 (CISM2-034)

When is a qualitative risk assessment MOST useful?

- A. When management requires an exact forecast of annual loss
- B. When vulnerability scores must be converted directly into currency
- C. When every scenario has extensive and statistically reliable loss data
- D. When consistent expert judgment is needed for initial prioritization despite limited numerical data

Question 8 (CISM2-035)

Scenario: A publisher values a digital production service at \$800,000. A disruptive event is expected to affect 25% of that value and occur 0.4 times per year. A proposed control costs \$95,000 annually and would remove most of this scenario's loss, with no other stated benefit.

Which conclusion is BEST supported by the annualized loss expectancy calculation?

- A. The annualized loss expectancy is \$320,000, so the control is justified
- B. The annualized loss expectancy is \$80,000, so the control requires additional business justification
- C. The annualized loss expectancy is \$200,000, so the control is justified
- D. The annualized loss expectancy is \$20,000, so the risk must be accepted

Question 9 (CISM2-036)

Scenario: A brokerage requires managers to review user access every month. The procedure excludes temporary contractors from the report, and evidence shows that reviews of included employees are completed on schedule.

What is the PRIMARY control issue?

- A. A threat event because contractors may retain access
- B. An operating deficiency because managers completed the reviews on time
- C. A design deficiency because the review population omits a relevant user group
- D. An impact because inappropriate access could affect transactions

Question 10 (CISM2-037)

Scenario: A mining company has two risk-register entries for the same operational network. One is rated high and one low, but neither records the assessment date, control assumptions, or business owner.

What should the information security manager do FIRST?

- A. Keep the high rating and delete the low rating as a conservative measure
- B. Average the ratings and assign the result to the network administrator
- C. Reconcile the scenario with the accountable owner and document scope, evidence, assumptions, and assessment date
- D. Close both records until a loss event establishes the correct rating

Question 11 (CISM2-038)

Scenario: An agricultural company plans to deploy internet-connected irrigation controllers supplied and remotely maintained by a startup. The pilot assessment considered crop data confidentiality but not remote command integrity, safety effects, vendor failure, or update support.

What is the MOST significant assessment gap?

- A. The scenarios omit operational impact, remote-control abuse, lifecycle support, and supplier dependency
- B. The assessment did not confirm that crop data has high confidentiality
- C. The pilot did not compare the controllers' purchase prices
- D. The startup has not experienced a publicly reported security event

Question 12 (CISM2-039)

Scenario: A nonprofit must prioritize two exposures with the same residual score. One affects a donation campaign beginning next week and could prevent payment processing. The other affects an internal archive with a tested manual workaround and no deadline-sensitive activity.

Which prioritization is MOST appropriate?

- A. Address the archive first because internal assets are easier to control
- B. Prioritize the payment exposure because its timing and effect on the campaign increase decision urgency
- C. Wait until one scenario occurs so actual impact can be compared
- D. Select randomly because equal scores indicate equal business significance

Question 13 (CISM2-040)

Scenario: A software company reports low residual risk for source-code theft because a data-protection control is funded and scheduled for deployment next quarter. Current controls leave the risk above tolerance.

How should the assessment be corrected?

- A. Report current residual risk above tolerance and identify low risk as the target after verified implementation
- B. Keep the low residual rating because approved funding makes the future control reliable
- C. Lower inherent risk because management has committed to treatment
- D. Remove the risk until the implementation project is completed

Question 14 (CISM2-041)

Scenario: One subsidiary rates likelihood by events per year, while another rates the likelihood that an event causes material loss after controls. Corporate management asks for a single heat map combining both sets of results.

What should the information security manager do before aggregating the ratings?

- A. Convert every rating to the higher of the two scales
- B. Map definitions, time horizons, control assumptions, and impact thresholds to a common basis
- C. Combine the scores because both methods use the term likelihood
- D. Exclude the subsidiary with fewer recorded events

Question 15 (CISM2-042)

Scenario: A retailer is choosing whether to expand same-day delivery. The assessment identifies a high-impact dependency on one routing-data provider, but event-frequency data is sparse. Executives must decide this week whether to fund an alternate provider.

Which presentation would BEST support the decision?

- A. A list of all technical findings at the routing-data provider
- B. Business scenarios with plausible impact ranges, key assumptions, response options, and decision points
- C. A single precise annual-loss figure without assumptions
- D. A recommendation to defer expansion until several years of loss data exist

Question 16 (CISM2-043)

Which action is the BEST example of transferring or sharing information security risk?

- A. Discontinuing an online service that creates the exposure
- B. Deploying a preventive control to reduce event likelihood
- C. Documenting a decision to retain the current residual risk
- D. Purchasing insurance that covers specified financial losses from an event

Question 17 (CISM2-044)

Who should formally accept residual information security risk?

- A. The designated business risk owner with authority under organizational policy
- B. The control operator who performs the daily procedure
- C. The assessor who calculated the residual-risk rating
- D. The information security manager in every case

Question 18 (CISM2-045)

Scenario: A museum plans an optional public feature that would allow visitors to upload executable interactive exhibits. Expected revenue is negligible, required safeguards would cost more than the feature's value, and the unmanaged risk is far above appetite.

Which response is MOST appropriate?

- A. Launch first and decide after observing attack activity
- B. Accept the exposure because the feature is optional
- C. Transfer all accountability to visitors through terms of use
- D. Avoid the risk by removing executable uploads from the planned feature

Question 19 (CISM2-046)

Scenario: A clinic considers two controls for unauthorized record access. Either control alone reduces likelihood but leaves residual risk above tolerance. Modeling shows that using both reduces risk within tolerance, and the combined cost is lower than the expected benefit of the service being protected.

What should the information security manager recommend?

- A. Implement the cheaper control alone because any likelihood reduction is sufficient
- B. Accept the remaining risk because both controls address the same scenario
- C. Implement both controls and verify that their combined operation achieves the expected residual risk
- D. Avoid the service because mitigation can never justify residual exposure

Question 20 (CISM2-047)

Scenario: A manufacturer contracts with a data-hosting provider. The agreement includes financial indemnification for specified breaches, but production still stops if the provider is unavailable and customers hold the manufacturer responsible for delivery.

How should the response be recorded?

- A. As complete transfer because the agreement includes indemnification
- B. As avoidance because infrastructure is no longer operated internally
- C. As acceptance because contracts do not affect risk
- D. As partial transfer with operational, customer, and accountability exposures retained

Question 21 (CISM2-048)

Scenario: A customer-data risk spans marketing, technology, and a call-center vendor. Each group operates one control, but no executive owns the business consequence or can approve funding for the complete treatment plan.

What should the information security manager do FIRST?

- A. Divide the risk into three unrelated entries and close the aggregate scenario
- B. Escalate for designation of a business risk owner with authority, while preserving control-owner responsibilities
- C. Ask the vendor to accept the entire risk because it operates a control
- D. Accept the risk temporarily on behalf of all participating groups

Question 22 (CISM2-049)

Scenario: A subscription service wants an early warning that account-takeover exposure is rising, not merely a count of tasks completed by the security team.

Which measure is the BEST key risk indicator?

- A. Number of security-awareness modules assigned this month
- B. Rate of high-confidence anomalous login attempts against customer accounts
- C. Hours spent maintaining the authentication platform
- D. Percentage of help-desk procedures reviewed on schedule

Question 23 (CISM2-050)

Scenario: A law firm discovers after signing a software contract that the supplier will store client files in an unapproved jurisdiction. Procurement says security review normally occurs during implementation.

Which change would BEST prevent recurrence?

- A. Prohibit all external software regardless of data use
- B. Review every supplier only after implementation details are finalized
- C. Require a risk-tiered security and data-location review before supplier selection and contract approval
- D. Ask project managers to accept supplier risk without documenting authority

Question 24 (CISM2-051)

Scenario: A factory system was approved for isolated use with local operator accounts. A change request would connect it to the corporate identity service and permit remote vendor maintenance, but the project labels the change routine.

What is the MOST appropriate response?

- A. Approve the change because centralized identity always lowers risk
- B. Reassess the risk because connectivity, threat access, and third-party dependencies have changed
- C. Retain the existing assessment because the factory process is unchanged
- D. Delegate acceptance to the vendor that will provide maintenance

Question 25 (CISM2-052)

Scenario: A media-streaming company accepts a temporary capacity risk on the condition that peak utilization remains below 80%. Monitoring shows utilization above 88% for three consecutive periods, meeting the documented review trigger.

What should the information security manager do NEXT?

- A. Wait for a service outage because utilization alone is not an incident
- B. Increase the threshold so the accepted risk remains valid
- C. Close the risk because monitoring is operating as designed
- D. Invoke the documented review with the risk owner and reassess the response

Question 26 (CISM2-053)

Scenario: A retailer permits 90-day exceptions to a device-security requirement. One business unit has renewed the same exception four times, the compensating control has never been tested, and the original approver has left the company.

What is the BEST action?

- A. Renew automatically because the business need has not changed
- B. Close the exception because the original approver is unavailable
- C. Reassess exposure and controls, then obtain a new authorized treatment decision.
- D. Convert the exception into permanent acceptance without further review

Question 27 (CISM2-054)

Scenario: A regional office cannot meet a mandatory data-retention security requirement before a new service launch. The local director offers to sign a risk acceptance, but policy does not authorize local leaders to waive legal obligations.

What should the information security manager do?

- A. Transfer the obligation to the technology team through a corrective-action ticket
- B. Accept the director's signature because the service belongs to the region
- C. Coordinate with legal and accountable leadership on a compliant response and escalate the launch decision
- D. Remove the requirement from the risk register until the service is operational

Question 28 (CISM2-055)

Scenario: Five divisions independently delay replacing the same vulnerable network appliance. Each delay falls within local tolerance, but all appliances depend on one support team and protect services used by the same major customer. The combined exposure exceeds enterprise appetite.

What should the information security manager report?

- A. The aggregate customer and support concentration risk, local decisions, trend, and enterprise action required
- B. Only the division with the oldest appliance
- C. Only the technical severity because local owners already approved the delays
- D. No issue until one division exceeds its local tolerance

Question 29 (CISM2-056)

Scenario: An online marketplace must reduce seller-fraud risk before holiday volume peaks. Option 1 immediately reduces risk within tolerance but adds minor onboarding friction. Option 2 preserves the current experience but will not be ready until after the peak. Both have similar cost and meet legal obligations.

Which response is BEST?

- A. Choose Option 2 because customer convenience always takes priority
- B. Accept the above-tolerance risk until Option 2 is ready without owner approval
- C. Choose Option 1 because it addresses the time-sensitive exposure within tolerance before the peak
- D. Deploy both options immediately even though one cannot be ready before the peak

Question 30 (CISM2-057)

Scenario: Executives receive a quarterly report containing hundreds of vulnerability counts. They cannot determine whether a delayed identity-modernization program has changed material exposure or whether further funding is needed.

Which report design would BEST support executive action?

- A. A complete export of vulnerability records sorted by technical score
- B. Material identity-risk scenarios, trends against appetite, control performance, forecast residual risk, and explicit funding decisions
- C. A list of security-team activities without links to risk outcomes
- D. A statement that risk cannot be reported until modernization is complete

Answer Key

Domain II - Information Security Risk Management

1 A	2 A	3 D	4 A	5 A
6 D	7 D	8 B	9 C	10 C
11 A	12 B	13 A	14 B	15 B
16 D	17 A	18 D	19 C	20 D
21 B	22 B	23 C	24 B	25 D
26 C	27 C	28 A	29 C	30 B

Detailed Explanations

Question 1 (CISM2-028)

Correct answer: A - The maximum level of risk the organization can absorb while remaining viable

Risk capacity is the maximum exposure the organization can absorb without threatening its viability. Residual risk remains after controls, risk tolerance defines acceptable variation around a specific limit, and risk appetite expresses the risk the organization is willing to pursue or retain.

Question 2 (CISM2-029)

Correct answer: A - The owner can relate loss of confidentiality, integrity, or availability to business objectives and consequences

The business owner understands how the asset supports objectives and can evaluate the business consequences of compromise. Technical configuration may belong to a control or system owner, no owner can guarantee complete vulnerability identification, and enterprise risk appetite is established through broader governance rather than by one asset owner.

Question 3 (CISM2-030)

Correct answer: D - Clarify applicable enterprise appetite, delegated tolerances, objectives, and accountability with the relevant leaders

The assessment needs approved criteria that reconcile the venture's objectives with the parent's commitments and delegated authority. Automatically adopting either party's operational preference may misstate acceptable exposure, while waiting for losses would leave the venture without a sound basis for current decisions.

Question 4 (CISM2-031)

Correct answer: A - Reassess the shared environment based on the dispatch dependency and availability impact

The dispatch dependency introduces a potentially significant availability impact that the website label did not capture. Public data sensitivity alone is insufficient, unrelated sites should not inherit criticality without evidence, and excluding the hosting environment would omit a central part of the risk scenario.

Question 5 (CISM2-032)

Correct answer: A - A correlated service interruption caused by the shared fourth-party dependency

The shared specialist creates concentration risk because one failure could disrupt all three reservation vendors. Outsourcing does not guarantee a breach, regional pricing is not the stated security exposure, and the contractual relationship alone does not establish whether a control has failed.

Question 6 (CISM2-033)

Correct answer: D - Remote access is the vulnerability, phishing is the threat, and rework and delay are impacts

Exposed remote access is an exploitable condition, phishing is threat activity, and rework or safety delay represents business impact. The other classifications reverse these distinct concepts, while grouping every element as a control deficiency would prevent meaningful likelihood and impact analysis.

Question 7 (CISM2-034)

Correct answer: D - When consistent expert judgment is needed for initial prioritization despite limited numerical data

A well-defined qualitative method supports initial comparison when reliable numerical data is limited. It does not produce exact financial forecasts, technical severity cannot be converted directly into loss, and extensive loss data may support a quantitative approach instead.

Question 8 (CISM2-035)

Correct answer: B - The annualized loss expectancy is \$80,000, so the control requires additional business justification

The single loss expectancy is \$800,000 multiplied by 25%, or \$200,000; multiplying by 0.4 gives an annualized loss expectancy of \$80,000. Because the control costs \$95,000 and no other benefit is stated, further justification or another response should be considered. The calculation alone does not require acceptance.

Question 9 (CISM2-036)

Correct answer: C - A design deficiency because the review population omits a relevant user group

The control is designed with an incomplete population, so it cannot address the full access risk even when performed as written. Timely execution indicates the documented procedure operated, possible retained access is a condition rather than a threat event, and possible transaction effects are impacts rather than the control issue itself.

Question 10 (CISM2-037)

Correct answer: C - Reconcile the scenario with the accountable owner and document scope, evidence, assumptions, and assessment date

The entries cannot support decisions without a common scenario, accountable owner, evidence, assumptions, and timing. Keeping or averaging unsupported ratings does not resolve the inconsistency, and closing the records would hide an exposure that can be reassessed without waiting for a loss.

Question 11 (CISM2-038)

Correct answer: A - The scenarios omit operational impact, remote-control abuse, lifecycle support, and supplier dependency

The assessment is too narrow for connected operational devices: command integrity, physical and production impact, update lifecycle, and supplier viability materially shape risk. Purchase price is not the central security gap, confidentiality should be assessed rather than assumed high, and lack of a known past event does not remove prospective exposure.

Question 12 (CISM2-039)

Correct answer: B - Prioritize the payment exposure because its timing and effect on the campaign increase decision urgency

The imminent campaign and direct effect on fundraising make the payment scenario more urgent even though the summary scores match. Ease of control is not the main priority criterion, equal scores can conceal material context, and waiting for a loss would fail to use the assessment proactively.

Question 13 (CISM2-040)

Correct answer: A - Report current residual risk above tolerance and identify low risk as the target after verified implementation

Current residual risk must reflect controls operating now, while the planned post-treatment level is target risk and depends on successful implementation. Funding does not make a future control effective today, treatment does not alter inherent exposure, and removing the risk would conceal the current above-tolerance condition.

Question 14 (CISM2-041)

Correct answer: B - Map definitions, time horizons, control assumptions, and impact thresholds to a common basis

The methods measure different conditions, so their definitions, time periods, control assumptions, and impact criteria must be aligned before aggregation. Selecting higher scores introduces bias, shared terminology does not make measures comparable, and event volume alone is not a valid reason to exclude a business unit.

Question 15 (CISM2-042)

Correct answer: B - Business scenarios with plausible impact ranges, key assumptions, response options, and decision points

Decision-makers need business consequences, ranges, assumptions, and response choices tied to the expansion decision. A technical list lacks strategic context, a precise point estimate would overstate the available evidence, and waiting years for more data would not address the current decision deadline.

Question 16 (CISM2-043)

Correct answer: D - Purchasing insurance that covers specified financial losses from an event

Insurance can transfer or share defined financial consequences, although accountability and other impacts remain. Discontinuing the activity is avoidance, implementing a preventive control is mitigation, and formally retaining exposure is acceptance.

Question 17 (CISM2-044)

Correct answer: A - The designated business risk owner with authority under organizational policy

Acceptance is a business decision made by the designated risk owner within policy-defined authority. Control operators and assessors provide execution or evidence, while the security manager facilitates analysis and advice but does not automatically own every business risk.

Question 18 (CISM2-045)

Correct answer: D - Avoid the risk by removing executable uploads from the planned feature

Removing the optional high-risk capability avoids the exposure and aligns with its low business value. Optional status does not justify accepting risk above appetite, terms cannot transfer all accountability, and launching before a response exposes the museum without a sound business reason.

Question 19 (CISM2-046)

Correct answer: C - Implement both controls and verify that their combined operation achieves the expected residual risk

The combined controls are proportionate and are the only stated option that reduces residual risk within tolerance; their effectiveness should then be verified. Cost alone does not make an insufficient control acceptable, overlap does not justify acceptance, and avoidance is premature when viable mitigation supports the service.

Question 20 (CISM2-047)

Correct answer: D - As partial transfer with operational, customer, and accountability exposures retained

Indemnification may shift specified financial consequences, but the manufacturer retains disruption, customer, and accountability impacts. Outsourcing does not avoid the underlying business activity, the contract does affect allocation of some loss, and its presence does not establish complete transfer.

Question 21 (CISM2-048)

Correct answer: B - Escalate for designation of a business risk owner with authority, while preserving control-owner responsibilities

The cross-functional scenario needs one accountable business owner with authority to coordinate and decide on treatment, while individual control owners retain their operating duties. A vendor cannot own all organizational consequences, splitting the scenario hides aggregate exposure, and the security manager should not assume acceptance authority.

Question 22 (CISM2-049)

Correct answer: B - Rate of high-confidence anomalous login attempts against customer accounts

The rate of credible anomalous attempts directly signals changing threat exposure related to account takeover. Training assignments, procedure reviews, and maintenance hours measure activity or performance but do not provide the same direct indication that the stated risk is increasing.

Question 23 (CISM2-050)

Correct answer: C - Require a risk-tiered security and data-location review before supplier selection and contract approval

Early, risk-tiered review preserves leverage to change suppliers, negotiate requirements, or obtain an authorized decision before commitment. Postponing review repeats the problem, prohibiting every external service is disproportionate, and undocumented acceptance by project managers may lack valid authority.

Question 24 (CISM2-051)

Correct answer: B - Reassess the risk because connectivity, threat access, and third-party dependencies have changed

The proposed connectivity and remote maintenance alter the threat surface, dependencies, and control assumptions, so the prior assessment is no longer sufficient. Centralized identity may add benefits and risks, an unchanged business process does not preserve the old exposure, and the vendor lacks authority to accept the factory's business risk.

Question 25 (CISM2-052)

Correct answer: D - Invoke the documented review with the risk owner and reassess the response

The agreed condition has been breached, so the manager should trigger reassessment and a new response decision with the authorized owner. Waiting defeats the leading indicator, changing the threshold after the fact conceals exposure, and effective monitoring does not mean the underlying risk is closed.

Question 26 (CISM2-053)

Correct answer: C - Reassess exposure and controls, then obtain a new authorized treatment decision.

Repeated renewal, untested compensation, and loss of the original approver require a fresh assessment and authorized decision. Automatic renewal lacks current evidence, closure would falsely imply resolution, and permanent acceptance cannot be inferred from an expired temporary exception.

Question 27 (CISM2-054)

Correct answer: C - Coordinate with legal and accountable leadership on a compliant response and escalate the launch decision

A local acceptance cannot waive a mandatory obligation, so legal and properly authorized leadership must determine a compliant response and decide whether the launch can proceed. A ticket does not transfer accountability, and removing the requirement would conceal rather than manage noncompliance.

Question 28 (CISM2-055)

Correct answer: A - The aggregate customer and support concentration risk, local decisions, trend, and enterprise action required

The shared customer and support dependencies create an enterprise exposure that local decisions do not reveal, so reporting should show aggregation, trend, prior decisions, and the required action. Focusing on one appliance or technical severity loses business context, and waiting ignores the existing breach of enterprise appetite.

Question 29 (CISM2-056)

Correct answer: C - Choose Option 1 because it addresses the time-sensitive exposure within tolerance before the peak

Option 1 meets the required risk level before the period of greatest exposure and imposes only a minor accepted business tradeoff. Option 2 misses the critical window, undocumented acceptance lacks authority, and deploying both is not feasible or justified by the stated costs and benefits.

Question 30 (CISM2-057)

Correct answer: B - Material identity-risk scenarios, trends against appetite, control performance, forecast residual risk, and explicit funding decisions

Executives need material scenarios connected to appetite, treatment performance, expected exposure, and decisions they own. Raw vulnerability data and activity lists lack business meaning, while delaying reporting would prevent leadership from addressing the program's current risk and funding needs.